

# PantryPilot Risk Management Report

---

Zixuan Liang

Harrisburg University of Science and Technology

CISC 594: Software Testing Principles and Techniques

Dr. Khalid Lateef

July 28, 2026

**Project: PantryPilot — Smart Meal and Grocery Planner**

## Executive Summary

This report identifies, scores, tracks, and controls the major risks for PantryPilot, the semester project for CISC 594. PantryPilot is a smart meal and grocery planner that maintains dietary profiles, recipe data, pantry inventory, weekly plans, AI-assisted substitutions, nutrition targets, and grocery lists. The risk-management approach follows a probability-by-impact model so that safety, correctness, external-dependency, privacy, and schedule risks can be compared on one scale.

The highest current risk is unsafe AI output because the system uses an LLM to propose substitutions and, in Version 2, generate recipes. The highest-priority control is therefore not another prompt; it is a deterministic safety layer that treats LLM output as untrusted and blocks allergen-containing suggestions before a user can see them. Other major risks are optimizer infeasibility, recipe API variability, pantry-expiry boundary defects, privacy exposure, grocery-list aggregation defects, and scope creep from V2 features.

## Risk Scoring Method

Each risk is assigned a probability score from 1 to 5 and an impact score from 1 to 5. The total risk score is calculated as probability multiplied by impact. This gives a maximum score of 25 and supports prioritization across risks that have different causes but compete for the same project time and testing effort.

Table 1

*Risk score calculation and priority bands*

| Score range | Priority | Interpretation                                              | Expected action                                                             |
|-------------|----------|-------------------------------------------------------------|-----------------------------------------------------------------------------|
| 20-25       | Critical | Could block release or create serious safety/trust failure. | Track every week; require design control and regression evidence.           |
| 12-19       | High     | Material project or user-impact risk.                       | Mitigate, assign test evidence, and review before baseline.                 |
| 6-11        | Medium   | Manageable but still relevant to quality or schedule.       | Monitor, test representative cases, and reduce when controls are effective. |
| 1-5         | Low      | Unlikely or minor under current scope.                      | Record if useful; retire when no longer relevant.                           |

## Current Risk Identification and Assessment

The current register contains seven risks. Six remain active or monitored, while the scope/schedule risk is marked as controlled because the project adopted a V1/V2 release boundary and a CM baseline. R1 through R5 are the most important risks because they could affect user safety, system correctness, test stability, or privacy.

**Table 2***Current PantryPilot risk register*

| ID | Category                  | Risk focus                         | P | I | Score | Status                       |
|----|---------------------------|------------------------------------|---|---|-------|------------------------------|
| R1 | Safety / AI output        | Unsafe LLM allergen output         | 5 | 5 | 25    | Critical; Active             |
| R2 | Algorithm / optimization  | Optimizer infeasibility or timeout | 4 | 5 | 20    | Critical; Active             |
| R3 | External dependency       | Recipe API instability             | 4 | 4 | 16    | High; Active                 |
| R4 | Boundary / date logic     | Pantry expiry boundary defect      | 3 | 5 | 15    | High; Active                 |
| R5 | Privacy / data protection | Sensitive profile-data exposure    | 3 | 4 | 12    | High; Active                 |
| R6 | Data correctness          | Grocery aggregation error          | 3 | 3 | 9     | Medium; Monitor              |
| R7 | Scope / schedule          | V2 scope expansion                 | 2 | 4 | 8     | Medium; Retired / controlled |

## Risk Rationale and Impact

### R1: Safety / AI output

Risk: LLM-generated substitution or recipe includes an ingredient, alias, or derivative that violates a declared allergy.

Assessment: probability  $5 \times$  impact  $5 = 25$  (Critical). The LLM is nondeterministic and user harm is possible if an unsafe ingredient bypasses the safety layer.

Control trigger: Any blocked allergen output, alias-list miss, or recipe generated without safety-filter evidence.

### R2: Algorithm / optimization

Risk: Nutrition optimizer cannot find a feasible weekly plan or consumes too much runtime under tight calorie, macro, allergy, and pantry constraints.

Assessment: probability  $4 \times$  impact  $5 = 20$  (Critical). V2 combines multiple constraints; infeasible or slow solver behavior can create silent failure or unusable planning results.

Control trigger: Solver timeout, empty plan, conflicting target bands, or user-visible result without a relaxation explanation.

### R3: External dependency

Risk: Recipe API responses are incomplete, inconsistent, rate-limited, or temporarily unavailable, causing failed ingestion or unstable tests.

Assessment: probability  $4 \times$  impact  $4 = 16$  (High). Spoonacular is outside project control and recipe fields may not match PantryPilot's canonical model.

Control trigger: API quota warning, missing ingredient quantity, missing nutrition values, or parser failure.

### R4: Boundary / date logic

Risk: Pantry expiry logic mishandles exact dates, promoting expired items or failing to prioritize near-expiry items.

Assessment: probability  $3 \times$  impact  $5 = 15$  (High). Date boundary defects directly affect food safety and can undermine the core waste-reduction feature.

Control trigger: Any recipe suggestion using an expired pantry item or failing an exact-boundary date test.

### R5: Privacy / data protection

Risk: Dietary profile, allergy, or health-target data is exposed through logs, configuration, test fixtures, or AI prompts.

Assessment: probability  $3 \times$  impact  $4 = 12$  (High). The project stores sensitive preference and health-related data even though it is not a regulated medical device.

Control trigger: Secret in repo, real personal data in tests, or prompt/log entry containing unnecessary sensitive profile details.

### R6: Data correctness

Risk: Unit conversion or grocery aggregation defects produce incorrect consolidated shopping lists.

Assessment: probability  $3 \times$  impact  $3 = 9$  (Medium). Wrong quantities reduce user trust and can cause waste, but the impact is lower than allergen or expired-food failures.

Control trigger: Mismatch between recipe ingredients and grocery list, or rounding behavior that changes planned servings materially.

### R7: Scope / schedule

Risk: V2 AI generation, optimizer, and pantry-aware planning expand beyond the semester project capacity.

Assessment: probability  $2 \times$  impact  $4 = 8$  (Medium). The risk was significant early, but versioning and CM baselines separated V1 deliverables from higher-complexity V2 work.

Control trigger: V2 feature merged before V1 baseline or required V1 acceptance test deferred by expansion work.

## Risk Mitigation and Control

Mitigation is documented for each tracked risk. The control design favors verification evidence that can be repeated during configuration audits and release reviews: regression tests, boundary tests, fixture-based integration tests, CI checks, and release baselines.

**Table 3**

*Mitigation plan and control evidence*

| Risk | Mitigation / control                                                                                                                                                          | Verification evidence                                                                                 | Owner / status                     |
|------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|------------------------------------|
| R1   | Treat all LLM output as untrusted; apply deterministic allergen alias matching before display; block unsafe output; log near-misses; keep an allergen regression suite in CI. | REQ-PP-Q2-002, REQ-PP-Q3-003, allergen-violation regression tests, safety telemetry events.           | Zixuan Liang; Active               |
| R2   | Bound solver runtime; define relaxation order; return partial plan with explicit relaxed-constraint notice; property-test generated constraint sets.                          | REQ-PP-Q1-001, REQ-PP-Q1-002, REQ-PP-Q3-002, feasibility tests and solver timeout checks.             | Zixuan Liang; Active               |
| R3   | Normalize all recipe inputs; reject under-specified recipes; cache API responses; use recorded fixtures for tests; provide seed/manual recipes as fallbacks.                  | Recipe normalization pipeline, cached fixtures, parser tests, seed-library fallback.                  | Zixuan Liang; Active               |
| R4   | Define an inclusive three-day near-expiry window; prohibit expired items; test today, +3 days, and yesterday boundary cases.                                                  | REQ-PP-Q1-003, REQ-PP-Q2-003, REQ-PP-Q3-001, boundary-date system tests.                              | Zixuan Liang; Active               |
| R5   | Store secrets outside version control; redact logs; avoid real personal data in fixtures; review configuration files before baselines.                                        | CM audit checklist, environment template, pull-request review for secrets and sensitive data.         | Zixuan Liang; Active               |
| R6   | Use canonical units after ingestion; add integration tests for duplicate ingredients, mixed units, and rounding rules.                                                        | Normalization pipeline, grocery-list integration tests, release checklist for known conversion cases. | Zixuan Liang; Monitor              |
| R7   | Keep V1 'Plan & Adapt' as the release baseline; open V2 work only after V1 tag, tests, and release notes are complete.                                                        | Project proposal V1/V2 boundary, CM baseline v1.0.0, release notes, branching strategy.               | Zixuan Liang; Retired / controlled |

## Week-by-Week Risk Tracking

The report maintains historical risk records rather than only showing the final score. Each weekly review re-examined whether risks should be added, re-scored, mitigated, monitored, or retired. A dash in the trend table means the risk had not yet been opened in the register for that week.

**Table 4**

*Weekly risk-management record*

| Week   | Review date | Project focus                      | Risk update                                                                                                                                                    | Score/action record                                                                                                 |
|--------|-------------|------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|
| Week 1 | Jun. 16     | Project proposal and initial scope | Identified AI-safety, API-dependency, grocery-correctness, and scope risks. Set V1/V2 boundary to avoid mixing optimizer work into the first release.          | Opened R1=25, R3=16, R6=12, R7=16.                                                                                  |
| Week 2 | Jun. 23     | Requirements and boundary analysis | Added optimizer infeasibility and pantry-date risks after ABC requirements clarified calorie bands, macro bands, expiry windows, and allergen prohibitions.    | Opened R2=20 and R4=15. Reduced R6 from 12 to 9 after canonical-unit design.                                        |
| Week 3 | Jun. 30     | Risk scoring normalized            | Applied a 1-5 probability and impact scale across all project risks. Added privacy/data-protection risk because profiles include allergies and health targets. | Opened R5=12. Kept R1=25 as top cross-version risk.                                                                 |
| Week 4 | Jul. 7      | Mitigation design                  | Paired each major risk with a control: deterministic allergen filter, API fixture cache, bounded solver, expiry boundary tests, and configuration review.      | R3 remained 16 because dependency probability is still high; R7 reduced from 16 to 12 after version-scope controls. |
| Week 5 | Jul. 14     | Configuration management package   | Established baseline v1.0.0, branch strategy, pull-request review, CI expectations, changelog, release notes, and configuration audit checklist.               | R7 reduced from 12 to 8 and marked controlled; R5 remained 12 pending regular secret/config review.                 |
| Week 6 | Jul. 21     | System testing plan                | Mapped risks to tests: allergen regression, optimizer feasibility/property tests, API parser fixtures, pantry-date boundary tests, and grocery                 | R1, R2, R3, and R4 stayed active because implementation defects would still affect release readiness.               |

|        |         |                      |                                                                                                                                                                                        |                                                                        |
|--------|---------|----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------|
|        |         |                      | aggregation tests.                                                                                                                                                                     |                                                                        |
| Week 7 | Jul. 28 | Risk report baseline | Reviewed the risk register for final reporting. No new top risk was added; R7 remained retired/controlled, while safety, optimizer, API, pantry-date, and privacy risks stayed active. | Current tracked scores: R1=25, R2=20, R3=16, R4=15, R5=12, R6=9, R7=8. |

**Table 5**

*Risk-score trend by week*

| Risk | W1 | W2 | W3 | W4 | W5 | W6 | W7 | Current status       |
|------|----|----|----|----|----|----|----|----------------------|
| R1   | 25 | 25 | 25 | 25 | 25 | 25 | 25 | Active               |
| R2   | -  | 20 | 20 | 20 | 20 | 20 | 20 | Active               |
| R3   | 16 | 16 | 16 | 16 | 16 | 16 | 16 | Active               |
| R4   | -  | 15 | 15 | 15 | 15 | 15 | 15 | Active               |
| R5   | -  | -  | 12 | 12 | 12 | 12 | 12 | Active               |
| R6   | 12 | 9  | 9  | 9  | 9  | 9  | 9  | Monitor              |
| R7   | 16 | 16 | 16 | 12 | 8  | 8  | 8  | Retired / controlled |

## Risk Retirement and Continuing Monitoring

R7 is the only retired or controlled risk in the current register. It was reduced because the project separated V1 from V2, created a configuration-management baseline, and defined release criteria before higher-risk V2 work begins. R6 is monitored because unit conversion and aggregation defects remain possible, but the mitigation is straightforward and the impact is lower than safety or privacy risks.

R1, R2, R3, R4, and R5 remain active. These risks should be reviewed before any implementation baseline because they connect directly to safety filtering, optimizer behavior, external dependency stability, expiry-date boundaries, and sensitive user data. The project should not tag a release unless the relevant controls have current test or audit evidence.

## Conclusion

The most important lesson from the PantryPilot risk analysis is that the system's smart behavior must be bounded by disciplined SQA controls. LLM-generated recipes and substitutions can add value, but the safety case depends on deterministic filtering, traceable requirements, CM baselines, and repeatable system tests. The weekly record shows that risks were not treated as a one-time list; they were opened, rescored, mitigated, monitored, and retired as the project scope became clearer.

## References

- Liang, Z. (2026a). PantryPilot — A smart meal and grocery planner [Course project proposal]. Harrisburg University of Science and Technology.
- Liang, Z. (2026b). PantryPilot — Software requirements in ABC format [Course assignment]. Harrisburg University of Science and Technology.
- Liang, Z. (2026c). PantryPilot configuration management generic files [Course assignment]. Harrisburg University of Science and Technology.
- Liang, Z. (2026d). PantryPilot final project presentation [Course presentation]. Harrisburg University of Science and Technology.